Table of Contents

Protocolos de seguridad de la información de XENTRA DATACLINIC

Versión: 1.0 · **Fecha:** noviembre de 2026 **Aplica a:** todas las personas que usan el sistema, el área de sistemas y la dirección de la IPS **Responsable de mantenerlo:** oficial de seguridad de la información (rol `auditor_sistemas`), con aprobación de la dirección

> **Cómo leer este documento.** Cada protocolo dice **por qué existe** (la norma que lo exige), **quién hace qué**, **los pasos** y **cómo lo hace cumplir el software**. Si usted es nuevo en el tema, lea primero la sección 1 y la tabla de roles de la sección 3: el resto son los procedimientos del día a día.
>
> **Importante.** Este documento es una guía técnica. Antes de adoptarlo como política oficial, revíselo con el área jurídica y el comité de historias clínicas de su IPS y ajústelo a su realidad (tamaño, sedes, convenios docencia-servicio).

Contenido

1. Principios y marco normativo
2. Decisión: sin portal del paciente
3. Roles del sistema y por qué existen
4. P-01 Gestión de usuarios (alta, cambio, baja y revisión)
5. P-02 Autenticación: contraseñas y segundo factor (MFA)
6. P-03 Acceso a la historia clínica
7. P-04 Estudiantes y refrendo docente
8. P-05 Validación de resultados de laboratorio
9. P-06 Separación de funciones administrativas
10. P-07 Revisión de accesos con el ledger (blockchain)
11. P-08 Uso aceptable
12. P-09 Respuesta a incidentes de seguridad
13. P-10 Respaldos, continuidad y contingencia
14. Matriz completa de roles y permisos
15. Configuración recomendada para producción
16. Creación de los usuarios de la institución
17. Formatos y registros
18. Lista de verificación para la puesta en producción

1. Principios y marco normativo

1.1 Los cinco principios

Principio	Qué significa en la práctica
Una persona, una cuenta	Nadie comparte usuario. Lo que se hace con una cuenta es responsabilidad de su titular
Mínimo privilegio	Cada persona ve **solo** lo que necesita para su trabajo. Sistemas administra el software, pero no lee historias clínicas
Necesidad de conocer	Aunque el rol permita ver historias, solo se abren las de los pacientes que se están atendiendo, auditando o facturando
Trazabilidad	Todo acceso y todo cambio queda en el ledger encadenado (blockchain), que no se puede alterar sin que se note
Separación de funciones	Quien crea un registro no es quien lo valida (estudiante/docente, auxiliar/bacteriólogo); quien administra no es quien audita

1.2 Normas en que se basa

Norma	Qué exige y dónde se aplica
Ley 23 de 1981 (ética médica), art. 34	La historia clínica es un documento privado y reservado → P-03
Resolución 1995 de 1999	Manejo de la historia clínica; art. 14: quiénes pueden acceder; custodia y confidencialidad → P-03, P-07
Resolución 839 de 2017	Tiempos de conservación de la historia clínica → P-10
Ley 2015 de 2020	Historia clínica electrónica interoperable → RDA, P-03
Resoluciones 1888 de 2025 y 1799 de 2026	Resumen Digital de Atención (RDA) ante la IHCE → P-03
Ley 1581 de 2012 y Decreto 1377 de 2013 (compilado en el Decreto 1074 de 2015)	Datos personales; los de salud son **datos sensibles**; deber de seguridad y de reporte de incidentes → P-03, P-09
Ley 1273 de 2009	Delitos informáticos (acceso abusivo, violación de datos personales) → P-08
Decreto 2376 de 2010	Relación docencia-servicio: los estudiantes actúan bajo supervisión del docente → P-04
Ley 841 de 2003	Ejercicio de la bacteriología: el bacteriólogo es responsable del resultado → P-05
Ley 266 de 1996, Ley 212 de 1995, Ley 485 de	Ejercicio de enfermería, química

Norma	Qué exige y dónde se aplica
1998	farmacéutica y regencia de farmacia (registro profesional) → P-01
Resolución 3100 de 2019	Habilitación: estándar de historia clínica y registros → todo el documento
ISO/IEC 27001:2022 (referencia, no obligatoria)	Controles 5.15–5.18 (acceso e identidades), 8.2 (accesos privilegiados), 8.5 (autenticación), 8.15 (registros), 5.24–5.28 (incidentes), 8.13 (respaldos)

2. Decisión: sin portal del paciente

La institución decidió que **los pacientes no ingresan a la plataforma**. Por eso:

- El portal viene **apagado** (`PORTAL_PACIENTE_ACTIVO=false`).
- No aparece el botón "Crear acceso al portal" en la ficha del paciente.
- Aunque existiera una cuenta de paciente antigua, el sistema **rechaza su ingreso** y cualquier llamada que haga.

Cómo se garantizan entonces los derechos del paciente (Ley 1581 de 2012 y Resolución 1995 de 1999):

Derecho	Cómo se atiende sin portal
Obtener copia de su historia clínica	Solicitud por escrito en admisiones → el médico o el archivo descarga el PDF firmado (con QR de verificación) y lo entrega. Plazo sugerido: 5 días hábiles
Saber quién consultó su historia	Solicitud por PQRS → el auditor genera el reporte de accesos desde el ledger (P-07)
Portabilidad de sus datos	Exportación FHIR desde la ficha del paciente (rol médico o admin), entregada en medio seguro
Continuidad de la atención en otra IPS	El RDA se envía a la IHCE, y las demás IPS lo consultan por interoperabilidad

Si en el futuro se quiere habilitar el portal, basta cambiar la variable a `true`, pero antes deben revisarse este protocolo y el aviso de privacidad.

---

3. Roles del sistema y por qué existen

Rol (en el sistema)	Para quién	Registro profesional	¿Ve historias clínicas?	Por qué existe
`admin`	Director(a) médico o	Recomendado	Sí	Responsable institucional;

Rol (en el sistema)	Para quién	Registro profesional	¿Ve historias clínicas?	Por qué existe
	gerente. **Máximo 2 personas**			decisiones que nadie más puede tomar (crear otros admin)
`admin_tecnico`	Ingeniero(a) de sistemas	No	**No**	Administra usuarios, sedes, camas, módulos y soporte **sin** ver datos clínicos (mínimo privilegio)
`medico`	Médicos generales y especialistas	**Sí** (ReTHUS)	Sí	Atiende, firma, ordena y refrenda a los estudiantes
`enfermeria`	Enfermeros(as) profesionales y auxiliares	**Sí**	Sí	Triage, notas, kárdex, signos, toma de muestras
`estudiante`	Internos, residentes y estudiantes en práctica	No (código estudiantil)	Sí, de los pacientes que atiende	Registra en borrador; **no firma**. Firma el docente (P-04)
`admisiones`	Recepción, citas, registro de pacientes	No	No	Datos demográficos y agenda
`facturacion`	Facturadores, cuentas médicas	No	No (solo lo necesario para facturar)	Facturas, RIPS, glosas
`farmacia`	Químico farmacéutico o regente	**Sí**	No	Inventario y dispensación
`laboratorio`	Bacteriólogos, radiólogos	**Sí**	No	Registra y **valida** resultados
`auxiliar_laboratorio`	Auxiliares de laboratorio	No	No	Toma muestras y digita resultados; **no valida** (P-05)
`auditor`	Auditor(a) médico	**Sí**	Sí (lectura)	Auditoría de calidad, de

Rol (en el sistema)	Para quién	Registro profesional	¿Ve historias clínicas?	Por qué existe
	(profesional de la salud)			historias y de cuentas
`auditor_sistemas`	Oficial de seguridad de la información	No	**No**	Revisa el ledger, los accesos y el estado del sistema; vigila a los administradores
`paciente`	—	—	—	**Deshabilitado** en esta institución (sección 2)

> **¿Por qué el administrador técnico no ve historias?** El art. 14 de la Resolución 1995 de 1999 limita el acceso a la historia al paciente, al equipo de salud, a las autoridades judiciales y de salud en los casos previstos por la ley y a quienes la ley autorice. El ingeniero de sistemas no está en esa lista. En hospitalización solo ve si una cama está "Ocupada", nunca el nombre del paciente.

---

4. P-01 Gestión de usuarios

Objetivo: que solo tengan cuenta las personas autorizadas, con el rol correcto y durante el tiempo que estén vinculadas. **Responsables:** jefe de cada área (solicita), talento humano (confirma vinculación), `admin_tecnico` o `admin` (ejecuta), `auditor_sistemas` (revisa).

4.1 Alta (persona nueva)

1. El jefe del área diligencia el **Formato F-01 Solicitud de usuario** (sección 17): nombre, documento, cargo, rol solicitado, sede, fecha de inicio y de fin (para contratistas y estudiantes).
2. Talento humano confirma que la persona tiene contrato o convenio vigente. Para estudiantes, el convenio docencia-servicio y el nombre del docente responsable.
3. **Verificación del registro profesional** para médicos, enfermería, laboratorio, farmacia y auditor: consultar el ReTHUS (Registro Único Nacional del Talento Humano en Salud) y guardar el pantallazo con el formato.
4. La persona firma el **acuerdo de confidencialidad y uso aceptable** (P-08).
5. El administrador crea la cuenta en **Usuarios → Nuevo usuario**:
   - Elige el rol. Debajo aparece qué hace ese rol y si ve historias clínicas.
   - Pulsa **Generar** para crear una clave temporal aleatoria.
   - El sistema **exige el registro profesional** en los roles que lo requieren.
   - Solo un `admin` puede crear otro `admin`.
6. La clave temporal se muestra **una sola vez**. Se entrega **en persona o en sobre cerrado**, nunca por WhatsApp ni por correo junto con el usuario.

7. En el primer ingreso, el sistema **obliga** a cambiar la clave (y a activar el MFA si su rol lo exige). Hasta hacerlo, no puede usar ninguna otra pantalla.
8. El alta queda en el ledger (`USUARIO_CREADO`) con quién la hizo y cuándo.

4.2 Cambio de rol o de área

- Se repite el Formato F-01, marcando "cambio".
- **Nunca se acumulan roles.** Si alguien pasa de facturación a admisiones, pierde los permisos de facturación.
- Si una persona necesita dos funciones de verdad (por ejemplo, un médico que también audita), tiene **dos cuentas distintas**, cada una con su clave y MFA.

4.3 Baja (retiro, fin de contrato o de práctica)

1. Talento humano o el jefe del área avisa **el mismo día** del retiro. Para estudiantes, el último día de la rotación.
2. El administrador pulsa **Desactivar** en Usuarios. **Nunca se borra** una cuenta: su firma debe seguir siendo verificable en las historias que elaboró.
3. Si la persona tenía MFA, no hace falta quitárselo: la cuenta desactivada no puede ingresar.
4. Queda en el ledger (`USUARIO_DESACTIVADO`).

4.4 Revisión periódica (recertificación)

Cada	Qué se revisa	Quién
Mes	Usuarios con clave **Temporal** por más de 7 días (nunca ingresaron) → desactivar	`admin_tecnico`
Mes	Usuarios con MFA **Pendiente (obligatorio)**	`admin_tecnico`
Trimestre	Lista completa de usuarios activos contra la nómina, los contratos y los convenios → desactivar a quien ya no esté	`auditor_sistemas` + talento humano
Trimestre	Cuántos `admin` hay (máximo 2) y si cada rol sigue siendo el adecuado	`auditor_sistemas` + dirección
Semestre	Estudiantes activos contra las rotaciones vigentes	Coordinación docencia-servicio

En **Usuarios**, el filtro por rol y las columnas **MFA** y **Clave** permiten hacer esta revisión en minutos. El resultado se firma en el **Formato F-03**.

---

5. P-02 Autenticación: contraseñas y segundo factor (MFA)

5.1 Contraseñas

Regla	Cómo la aplica el sistema
Mínimo 10 caracteres, con mayúsculas, minúsculas y números	Se valida al crear y al cambiar
Clave temporal obligatoria de cambiar en el primer ingreso	`CAMBIO_CLAVE_PRIMER_INGRESO=true`: bloquea todo hasta cambiarla
No reutilizar la temporal	El sistema rechaza que la nueva sea igual a la actual
Bloqueo tras intentos fallidos	5 intentos → 15 minutos de bloqueo (`MAX_INTENTOS_LOGIN`, `MINUTOS_BLOQUEO`)
Almacenamiento seguro	Argon2id: ni el administrador ni la base de datos conocen las claves
Cierre por inactividad	La pantalla cierra la sesión a los 15 minutos sin uso; el token vence a los 30 minutos (`ACCESS_TOKEN_EXPIRE_MINUTES`) si no se renueva; y la sesión termina al cerrar el navegador

Recomendaciones a los usuarios: usar una frase (por ejemplo `MiPerroCome3VecesAlDia`), no usar la misma clave de otros sitios, no escribirla en papeles pegados al monitor, y no guardarla en el navegador de un equipo compartido.

5.2 Segundo factor (MFA)

El MFA usa un código de 6 dígitos que cambia cada 30 segundos, generado en el celular (Google Authenticator, Microsoft Authenticator o Authy).

Obligatorio para los roles definidos en `MFA_OBLIGATORIO_ROLES`. Recomendación:

```
MFA_OBLIGATORIO_ROLES=admin,admin_tecnico,auditor,auditor_sistemas,medico,facturacion
```

- `admin`, `admin_tecnico`, `auditor_sistemas`: tienen las llaves del sistema.
- `medico` y `auditor`: acceden a muchas historias y firman.
- `facturacion`: maneja dinero y datos que van a la DIAN y a las EPS.

Quien tenga un rol obligatorio y no haya activado el MFA es enviado a **Mi cuenta** y no puede trabajar hasta activarlo. Se puede ampliar a todos los roles cuando la institución esté lista.

5.3 Reposición del MFA (celular perdido o cambiado)

Esta es la puerta favorita de los atacantes (“hola, soy el doctor, perdí el celular, quíteme la clave”). Por eso:

1. La persona se presenta **personalmente** con su documento de identidad, o por videollamada con el documento visible si está en otra sede.
2. El administrador verifica que el documento coincida con el de la cuenta.
3. Diligencia el **Formato F-02 Reposición de MFA**.
4. Pulsa **Activo ✕** en la columna MFA. Queda en el ledger (`MFA_DESACTIVADO`, con el administrador que lo hizo).
5. La persona activa de inmediato el MFA en su nuevo celular.
6. **Nunca** se repone el MFA por una llamada, un chat o un correo.
7. El MFA de un `admin` solo lo repone el otro `admin`.

---

6. P-03 Acceso a la historia clínica

Quién puede abrir historias: `medico`, `enfermeria`, `estudiante`, `auditor` y `admin`. Los demás roles no tienen la opción, y el servidor rechaza la petición aunque alguien intente llamar a la API directamente.

Reglas:

1. Solo se abren las historias de pacientes **con relación asistencial, de auditoría o de facturación vigente**. Tener permiso técnico no autoriza a curiosear (por ejemplo, la historia de un compañero, un familiar o un personaje público).
2. **Cada apertura queda registrada** en el ledger (`CONSULTA_HC`, `CONSULTA_ATENCION`, `DESCARGA_PDF`, `FHIR_EXPORTACION`, `RESUMEN_HC`) con usuario, fecha, hora e IP.
3. Lo firmado **no se modifica**: las correcciones se hacen con **notas aclaratorias**, también selladas. La base de datos bloquea cualquier modificación de un folio firmado.
4. Las copias impresas o en PDF solo se entregan al paciente, a su representante legal o a la autoridad competente, con solicitud escrita archivada.
5. La historia se envía a otras instituciones **solo** por los canales oficiales (RDA a la IHCE) o por solicitud formal.
6. Las pantallas no se dejan abiertas sin vigilancia. Bloquee el equipo (`Windows + L`) al levantarse.

Acceso de autoridades: las solicitudes de jueces, fiscalía, Supersalud o secretarías de salud se canalizan por el área jurídica. La entrega se hace en PDF firmado, y queda en el ledger quién lo descargó.

---

7. P-04 Estudiantes y refrendo docente

Base: Decreto 2376 de 2010. En la relación docencia-servicio, el estudiante actúa **bajo la supervisión** del docente o profesional responsable, quien responde por la atención.

Cómo funciona en el software:

```
Estudiante                          Sistema
Médico docente
```

```
_____                                  _______
_____________

Abre la ficha del paciente  ──►
Registra la atención (SOAP) ──►  Guarda en BORRADOR
                                  (no tiene botón Firmar;
                                   si intenta firmar por API → 403)
                                  Aparece en Inicio del médico ──►
"Registros de estudiantes

pendientes de su refrendo"

Revisa, corrige si es necesario

Pulsa "Refrendar y firmar"
                                  Sella el folio con el hash ◄──
                                  Guarda: autor = estudiante,
                                  firma = médico (supervisor)
                                  Ledger: ATENCION_REFRENDADA
```

Reglas:

1. El estudiante tiene su propia cuenta (rol `estudiante`) con su código estudiantil en "Registro profesional".
2. **Nunca** usa la cuenta del docente, ni el docente le presta la suya.
3. El docente revisa **todo** el registro antes de refrendar. Al refrendar, asume la responsabilidad del contenido.
4. El PDF de la atención muestra "Elaborado por (estudiante)" y "Refrendado por (docente, registro)". La firma del documento es la del docente.
5. Los borradores de estudiantes no refrendados se revisan **a diario**. Un borrador no tiene validez legal.
6. Al terminar la rotación, la cuenta se desactiva (P-01, 4.3).

---

8. P-05 Validación de resultados de laboratorio

Base: Ley 841 de 2003. El bacteriólogo es el profesional responsable de los resultados que emite el laboratorio clínico.

Paso	`auxiliar_laboratorio`	`laboratorio` (bacteriólogo)
Ver órdenes pendientes	✔️	✔️
Registrar la toma de la muestra	✔️	✔️
Digitar resultados	✔️	✔️
Validar (liberar al médico, sellar con hash)	✘ (el sistema lo impide)	✔️

Hasta que el bacteriólogo valide, el médico **no** ve el resultado como definitivo. El resultado validado queda sellado con hash y en el ledger.

---

9. P-06 Separación de funciones administrativas

Situación	Control
Número de `admin`	Máximo 2 (director médico y gerente o su delegado). Se revisa cada trimestre
Crear o modificar un `admin`	Solo otro `admin`; el `admin_tecnico` no puede
El ingeniero de sistemas administra el software	Usa `admin_tecnico`: no ve historias, solo ocupación de camas
¿Quién vigila a los administradores?	El `auditor_sistemas` revisa en el ledger lo que hacen los administradores. No puede crear usuarios ni cambiar configuración
Cuenta `admin@xentra.co` inicial	Se usa solo para crear las cuentas personales de los administradores. Luego **se desactiva** o se le cambia la clave y se guarda en sobre sellado (cuenta de emergencia)
Acceso al servidor (SSH, base de datos)	Solo el área de sistemas, con llave SSH y, si es posible, por VPN. La aplicación usa el usuario de BD `xentra_app`, sin permisos para borrar el ledger

10. P-07 Revisión de accesos con el ledger (blockchain)

Responsable: `auditor_sistemas` (seguridad) y `auditor` (clínico). **Dónde:** menú **Seguridad blockchain**.

Frecuencia	Actividad	Qué buscar
Diaria	Panel de Inicio: estado de la cadena	Debe decir “íntegra”
Semanal	**Verificar cadena completa**	Cualquier bloque roto = incidente (P-09)
Semanal	Filtrar `LOGIN_FALLIDO` y `MFA_FALLIDO`	Muchos intentos sobre una cuenta, o intentos de madrugada
Mensual	Accesos a historias (`CONSULTA_HC`)	Usuarios que abren muchas historias sin atenciones asociadas; accesos a historias de empleados o personajes públicos; accesos fuera del

Frecuencia	Actividad	Qué buscar
		turno
Mensual	Acciones administrativas (`USUARIO_CREADO`, `USUARIO_ACTIVADO`, `USUARIO_DESACTIVADO`, `MFA_DESACTIVADO`, `CLAVE_CAMBIADA`)	Altas sin Formato F-01, reposiciones de MFA sin F-02
Mensual	Anclaje externo	Que exista un anclaje reciente (OpenTimestamps o local)

Los hallazgos se registran en el **Formato F-03** y se informan al comité de historias clínicas. Un acceso indebido se trata como incidente (P-09) y como posible falta disciplinaria.

---

11. P-08 Uso aceptable

Toda persona con cuenta firma este compromiso antes de recibirla:

1. Mi usuario y mi clave son personales e intransferibles. Lo que se haga con ellos es mi responsabilidad.
2. Solo consulto la información que necesito para mi trabajo.
3. No tomo fotos de la pantalla, no copio datos a USB, a correos personales ni a chats, y no imprimo sin necesidad.
4. Cierro sesión o bloqueo el equipo cuando me levanto.
5. Reporto de inmediato cualquier situación sospechosa: correos que piden mi clave, accesos que no reconozco, equipos desbloqueados.
6. Conozco que el acceso abusivo a un sistema informático y la violación de datos personales son delitos (Ley 1273 de 2009), y que la historia clínica es reservada (Ley 23 de 1981, Resolución 1995 de 1999).
7. Sé que todas mis acciones quedan registradas en un registro inalterable.

---

12. P-09 Respuesta a incidentes de seguridad

Qué es un incidente: acceso indebido a historias, cuenta comprometida, clave compartida, cadena del ledger rota, equipo con datos perdido o robado, malware, fuga de información, o caída por ataque.

Paso	Qué hacer	Quién	Tiempo
1. Reportar	Avisar al oficial de seguridad (o a sistemas, si no está) y crear un ticket en	Cualquier persona	Inmediato

Paso	Qué hacer	Quién	Tiempo
	Soporte con categoría “seguridad”		
2. Contener	Desactivar la cuenta comprometida, reponer el MFA, cambiar `SECRET_KEY` si se sospecha robo de sesiones (cierra todas), aislar el equipo	`admin_tecnico`	Primera hora
3. Evaluar	Revisar en el ledger qué se hizo con la cuenta: qué historias se abrieron y qué se modificó. Verificar la cadena completa	`auditor_sistemas`	24 horas
4. Erradicar y recuperar	Corregir la causa. Si hay alteración, restaurar desde un respaldo verificado (P-10)	Sistemas	Según el caso
5. Notificar	**A la SIC**: reportar el incidente en el Registro Nacional de Bases de Datos dentro de los **15 días hábiles** siguientes a su detección (Ley 1581 de 2012). **A los titulares** afectados, si el riesgo lo amerita. **ColCERT** (colcert.gov.co) para incidentes cibernéticos. **Fiscalía** si hay delito	Dirección + jurídica	Según plazo
6. Aprender	Informe del incidente (F-04), lecciones aprendidas y ajuste de este protocolo	Oficial de seguridad	30 días

Ante la duda, **reporte**. Un incidente reportado a tiempo es un problema pequeño; uno escondido es uno grande.

13. P-10 Respaldos, continuidad y contingencia

- **Respaldo automático diario** de la base de datos (contenedor `respaldo`, conserva `RESPALDO_DIAS`).
- **Regla 3-2-1:** 3 copias, en 2 medios distintos, 1 fuera de la institución (nube cifrada o disco en otra sede).
- **Respaldar aparte las llaves** `SECRET_KEY` y, sobre todo, `LEDGER_HMAC_KEY`. Sin esta última no se pueden verificar los bloques antiguos. Se guardan en sobre sellado en la caja fuerte de la dirección y en un gestor de contraseñas.
- **Prueba de restauración trimestral** en un equipo de pruebas: un respaldo que nunca se ha restaurado no es un respaldo.
- **Conservación de la historia clínica:** según la Resolución 839 de 2017. Las historias **no se borran** del sistema; los pacientes y usuarios se desactivan.
- **Contingencia:** si el sistema no está disponible, se usan los formatos en papel del plan de continuidad (`docs/11-plan-continuidad.md`) y se transcriben al restablecer el servicio, indicando que es un registro diferido.

14. Matriz completa de roles y permisos

Leyenda: S = sí, acceso completo · **L** = solo lectura · **P** = parcial (ver notas) · · = sin acceso

Columnas: ADM `admin` · ATC `admin_tecnico` · MED `medico` · ENF `enfermeria` · EST `estudiante` · ADI `admisiones` · FAC `facturacion` · FAR `farmacia` · LAB `laboratorio` · AUX `auxiliar_laboratorio` · AUD `auditor` · AUS `auditor_sistemas`

Módulo	ADM	ATC	MED	ENF	EST	ADI	FAC	FAR	LAB	AUX	AUD	AUS
Pacientes (buscar, registrar)	S	·	S	S	S	S	·	·	·	·	L	·
Historia clínica: leer	S	·	S	S	S	·	·	·	·	·	L	·
Historia clínica: registrar	S	·	S	S	P	·	·	·	·	·	·	·
Historia clínica: firmar	S	·	S	S	·	·	·	·	·	·	·	·
Refrendar estudiantes	S	·	S	·	·	·	·	·	·	·	·	·
Asistente IA CIE-10	S	·	S	S	S	·	·	·	·	·	·	·
Agenda y citas	S	·	S	S	·	S	·	·	·	·	·	·
Urgencias / triage	S	·	S	S	·	S	·	·	·	·	·	·
Hospitalización	S	P	S	S	·	S	·	·	·	·	L	·
Laboratorio: tomar y digitar	S	·	S	P	·	·	·	·	S	S	·	·
Laboratorio: validar	S	·	S	·	·	·	·	·	S	·	·	·
Farmacia	S	·	·	·	·	·	·	S	·	·	·	·
Facturación electrónica	S	·	·	·	·	·	S	·	·	·	L	·

Módulo	ADM	ATC	MED	ENF	EST	ADI	FAC	FAR	LAB	AUX	AUD	AUS
RIPS (generar y validar)	S	·	·	·	·	·	S	·	·	·	·	·
Indicadores	S	·	P	·	·	·	·	·	·	·	S	P
SIVIGILA	S	·	S	·	·	·	·	·	·	·	S	·
Inteligencia de negocio	S	·	S	S	·	S	S	S	S	·	S	·
RDA (cola de envío IHCE)	S	S	·	·	·	·	·	·	·	·	S	S
Seguridad blockchain (ledger)	S	S	·	·	·	·	·	·	·	·	S	S
Usuarios	S	P	·	·	·	·	·	·	·	·	·	·
Sedes, camas, módulos	S	S	·	·	·	·	·	·	·	·	·	·
Estado del sistema	S	S	·	·	·	·	·	·	·	·	S	S
Soporte: avisos y gestión de tickets	S	S	·	·	·	·	·	·	·	·	L	L
Soporte: crear ticket	S	S	S	S	S	S	S	S	S	S	S	S
Mi cuenta (clave y MFA)	S	S	S	S	S	S	S	S	S	S	S	S

Notas (parciales): - **EST – registrar HC:** solo en borrador; lo firma el docente (P-04). - **ATC – hospitalización:** solo crea y mantiene camas y ve su ocupación, sin nombres de pacientes. - **ENF – laboratorio:** registra la toma de muestras; no digita ni valida resultados. - **MED – indicadores:** indicadores clínicos y SIVIGILA. **AUS – indicadores:** solo cifras agregadas de gerencia, sin datos de pacientes. - **ATC – usuarios:** crea y desactiva a todos excepto a los `admin`. - **Módulos adicionales:** cada módulo define qué roles lo usan (lo configura el administrador). - "Leer HC" del estudiante: solo para registrar la atención del paciente que atiende (P-03, regla 1). - Los permisos se verifican **en el servidor**, no solo en el menú: aunque alguien escriba la dirección a mano o use la API, recibe "403 – No autorizado".

---

15. Configuración recomendada para producción

Agregue o revise en el archivo `.env` del servidor:

```
# --- Protocolos de seguridad (docs/manuales/04-PROTOCOLOS-
SEGURIDAD.md) ---
# Pacientes NO ingresan a la plataforma
PORTAL_PACIENTE_ACTIVO=false
# Clave temporal: obligatorio cambiarla en el primer ingreso
CAMBIO_CLAVE_PRIMER_INGRESO=true
# Roles que no pueden trabajar sin segundo factor
MFA_OBLIGATORIO_ROLES=admin,admin_tecnico,auditor,auditor_sistemas,med
ico,facturacion
# Bloqueo por intentos fallidos
MAX_INTENTOS_LOGIN=5
MINUTOS_BLOQUEO=15
```

```
# Datos de ejemplo: APAGADOS en producción (no crear usuarios demo)
CARGAR_DATOS_DEMO=false
```

Después de cambiar el `.env`, reinicie: `docker compose up -d`.

> **Usuarios de demostración.** Con `CARGAR_DATOS_DEMO=true` se crean cuentas de ejemplo con la clave `Demo12345*` (por ejemplo `sistemas@xentra.co`, `seguridad@xentra.co`, `residente@xentra.co`, `auxiliar.laboratorio@xentra.co`). Sirven **solo** para pruebas y capacitación. En producción deben estar apagadas, y si se cargaron por error, **desactívelas**.

---

16. Creación de los usuarios de la institución

16.1 Uno por uno

Menú **Usuarios** → **Nuevo usuario** (P-01, 4.1).

16.2 Carga masiva (recomendado para el arranque)

1. Copie la plantilla `docs/plantillas/usuarios_institucion.csv`. Trae los 14 perfiles recomendados para una IPS: director, sistemas, médicos, enfermería, interno, admisiones, facturación, farmacia, bacteriología, auxiliar de laboratorio, auditor médico y oficial de seguridad.

2. Ábrala en Excel y reemplace los datos de ejemplo por los reales. Una fila por persona. Separador `;` y columnas:

   ```
   tipo_documento;numero_documento;nombres;apellidos;email;rol;registro_profesional;especialidad
   ```

   Los roles válidos son: `admin`, `admin_tecnico`, `medico`, `enfermeria`, `estudiante`, `admisiones`, `facturacion`, `farmacia`, `laboratorio`, `auxiliar_laboratorio`, `auditor`, `auditor_sistemas`.

3. Guárdela como **CSV (delimitado por punto y coma)** con codificación UTF-8.

4. Cárguela en el servidor:

   ```
   docker compose cp usuarios.csv backend:/tmp/usuarios.csv
   docker compose exec backend python -m app.crear_usuarios
   /tmp/usuarios.csv --salida /tmp/credenciales.csv
   docker compose cp backend:/tmp/credenciales.csv
   ./credenciales.csv
   docker compose exec backend rm /tmp/usuarios.csv
   /tmp/credenciales.csv
   ```

5. El programa:

   - valida cada fila (rol válido, correo no repetido, registro profesional en los roles que lo exigen);

- crea las cuentas con una **clave temporal aleatoria** distinta para cada persona;
- las marca para **cambio obligatorio** en el primer ingreso;
- registra cada alta en el ledger;
- muestra los errores por fila sin detener las demás.

6. `credenciales.csv` contiene las claves temporales: **imprima un sobre por persona, entréguelo en mano y borre el archivo**.

---

17. Formatos y registros

Código	Formato	Contenido mínimo	Se archiva
F-01	Solicitud de alta, cambio o baja de usuario	Datos de la persona, rol, sede, fechas, firma del jefe, verificación ReTHUS, firma de quien ejecuta	Talento humano
F-02	Reposición de MFA	Fecha, usuario, documento verificado, medio (presencial o video), firma del administrador	Sistemas
F-03	Revisión periódica de accesos	Periodo, usuarios revisados, hallazgos, acciones, firmas	Oficial de seguridad
F-04	Informe de incidente	Descripción, línea de tiempo, alcance, contención, notificaciones, lecciones	Oficial de seguridad
F-05	Acuerdo de confidencialidad y uso aceptable	Texto de P-08 + firma	Hoja de vida

18. Lista de verificación para la puesta en producción

- ☐ `.env` con los valores de la sección 15 (`PORTAL_PACIENTE_ACTIVO=false`, `CARGAR_DATOS_DEMO=false`).
- ☐ `SECRET_KEY` y `LEDGER_HMAC_KEY` nuevas, largas y respaldadas en sobre sellado.
- ☐ Cuentas personales de los 1 o 2 `admin` creadas; la cuenta inicial `admin@xentra.co` desactivada o en sobre sellado.
- ☐ Usuarios reales cargados (sección 16), con Formato F-01 y acuerdo F-05 firmados.
- ☐ MFA activo en todos los roles obligatorios (columna MFA sin “Pendiente”).

- ☐ Docentes informados del refrendo y estudiantes con su propia cuenta.
- ☐ Verificación completa de la cadena en estado “íntegra”.
- ☐ Respaldo automático funcionando, copia externa configurada y una restauración probada.
- ☐ HTTPS activo (`docker-compose.prod.yml` con dominio).
- ☐ Calendario de revisiones (P-01, 4.4 y P-07) asignado a responsables.
- ☐ Procedimiento de incidentes (P-09) socializado, con los teléfonos del oficial de seguridad publicados.